

CYBER SECURITY



NIST Security Framework Er. Prakash Chandra Adhikari

Introduction to NIST Cybersecurity Framework

- The **NIST Cybersecurity Framework (CSF)** is a **risk-based, voluntary framework** developed by the **National Institute of Standards and Technology (NIST)** to help organizations **identify, assess, manage, and reduce cybersecurity risk**.
- First released: **2014**
- Major update: **CSF 2.0 (2024)**
- Applicable to: **All sectors** (financial institutions, healthcare, government, SMEs, critical infrastructure)



Purpose of NIST Cybersecurity Framework

NIST CSF helps organizations to:

- Understand **current cybersecurity posture**
- Prioritize **cybersecurity investments**
- Improve **risk management**
- Communicate cybersecurity risks to **management and stakeholders**
- Prepare for, respond to, and recover from **cyber incidents**

Important:

NIST CSF is **NOT only for after a cyberattack.**

It is used:

- **Before** an incident (prevention & preparedness)
- **During** an incident (response)
- **After** an incident (recovery & improvement)

Core Components of NIST CSF

- NIST CSF has **three main components**:
- **Framework Core**
- **Implementation Tiers**
- **Profiles**

Framework Core

- The **Framework Core** is the **foundation** of NIST CSF. It describes **what cybersecurity activities should be done**.
- Organized into **6 Functions**:
Govern, Identify, Protect, Detect, Respond, Recover
- Each function is further divided into **Categories** and **Subcategories**
- Focuses on **outcomes**, not specific technologies
-  **Purpose:**
To provide a **standard set of cybersecurity activities** that help manage cyber risk.
-  *Example:*
“Protect” includes access control, data security, and user awareness.

Implementation Tiers

- **Implementation Tiers** describe **how well** an organization manages cybersecurity risk.
- They measure **maturity**, not security strength
- Reflect integration of cybersecurity into **risk management and decision-making**
- **Four Tiers:**
 - **Tier 1 – Partial:** Ad-hoc, reactive, undocumented practices
 - **Tier 2 – Risk-Informed:** Some policies, limited consistency
 - **Tier 3 – Repeatable:** Formal, documented, consistently applied
 - **Tier 4 – Adaptive:** Proactive, continuously improving, threat-driven
- **◆ Purpose:**
To help organizations understand their **current capability level** and plan improvement.

Profiles

- A **Profile** aligns the Framework Core with **business needs, risk tolerance, and resources**.
- **Current Profile:** What controls and practices exist now
- **Target Profile:** What controls and practices are desired
- The gap between the two helps in **prioritizing improvements**.
-  **Purpose:**
To customize NIST CSF for a **specific organization or sector**.
-  *Example:*
A bank's Target Profile may require stronger access control than its Current Profile

Main Theme

- **Framework Core:** *What to do*
- **Implementation Tiers:** *How well it is done*
- **Profiles:** *Where you are vs where you want to be*



What is NIST CSF 2.0?

- NIST CSF 2.0 is the **latest and official cybersecurity risk management framework** published by **NIST (National Institute of Standards and Technology)**.
- It is designed to help **all types of organizations** (government, private, SMEs, critical infrastructure) to:
 - Manage cybersecurity risks
 - Improve governance and accountability
 - Align security with business objectives
 - Integrate cybersecurity into enterprise risk management (ERM)

Where NIST Cybersecurity Framework 2.0 Fits in the Cyber Lifecycle

1. Before a Cyber Attack (PRIMARY USE)

This is **the main reason CSF exists.**

- **Functions used:**
- **Govern**
- **Identify**
- **Protect**
- **Detect**

Where NIST Cybersecurity Framework 2.0 Fits in the Cyber Lifecycle

What happens *before* an attack:

- Define cybersecurity **governance and policies**
- Identify critical assets and risks
- Implement security controls
- Establish monitoring and detection
- Train staff and assign responsibilities
- 📌 **80–90% of CSF implementation work happens here**
- **Example:**
A bank implements CSF 2.0 to:
 - Reduce ransomware risk
 - Meet regulatory expectations
 - Prepare incident response in advance

Where NIST Cybersecurity Framework 2.0 Fits in the Cyber Lifecycle

2. During a Cyber Attack

- **Functions used:**
- **Detect**
- **Respond**
- **What CSF helps with:**
- Early detection of incidents
- Clear incident response roles
- Containment and communication
- Legal and regulatory notification
- 📌 CSF does **not replace** IR tools, but **defines the process and accountability.**

Where NIST Cybersecurity Framework 2.0 Fits in the Cyber Lifecycle

3. After a Cyber Attack

- **Functions used:**
- **Recover**
- **Govern** (feedback loop)
- **What happens *after* an attack:**
- Restore systems and services
- Perform lessons-learned review
- Update risk register
- Improve controls and policies
- Raise maturity tier if needed

 CSF is used to **strengthen posture after incidents**, not just respond once.

Where NIST Cybersecurity Framework 2.0 Fits in the Cyber Lifecycle

When Do Organizations Usually Start CSF?

Scenario	CSF Implementation
No incident yet	✓ Best practice
Regulatory requirement	✓ Common
After ransomware attack	✓ Very common
Audit finding	✓ Common
Digital transformation	✓ Recommended

Where NIST Cybersecurity Framework 2.0 Fits in the Cyber Lifecycle

Why People Think It's "After an Attack"

Because many organizations:

- Ignore cybersecurity until an incident happens
- Then adopt CSF as a **corrective framework**

 **That is reactive use, not intended use**

Preventive vs Reactive Functions in NIST Cybersecurity Framework 2.0

PREVENTIVE FUNCTIONS

- *(Before an attack – reduce likelihood & impact)*

1. GOVERN (Strategic Prevention)

- **Nature:** Preventive (Foundational)

Why preventive:

- Establishes **policies, roles, accountability**
- Aligns cybersecurity with **risk appetite**
- Ensures funding, oversight, and compliance

Examples:

- Board-approved cyber risk policy
- Defined ransomware response authority
- Third-party risk governance
-  *No governance → high probability of failure.*

Preventive vs Reactive Functions in NIST Cybersecurity Framework 2.0

2.IDENTIFY (Risk Prevention)

Nature: Preventive

Why preventive:

- Identifies assets, data, threats, and risks **before exploitation**
- Enables prioritization of critical systems

Examples:

- Asset inventory
- Data classification
- Risk assessment & BIA

Preventive vs Reactive Functions in NIST Cybersecurity Framework 2.0

3.PROTECT (Control-Based Prevention)

- **Nature:** Preventive

Why preventive:

- Implements safeguards to **stop or limit attacks**

Examples:

- MFA, access control
- Backup strategy
- Security awareness training
- Network segmentation

Preventive vs Reactive Functions in NIST Cybersecurity Framework 2.0

DETECTIVE FUNCTION

- *(Bridges prevention and reaction)*

4.DETECT

Nature: Preventive + Reactive (Early-Warning)

Why both:

- Does not stop attacks
- **Reduces dwell time**
- Enables faster response

Examples:

- SIEM alerts
- Log monitoring
- Anomaly detection
-  *Early detection = less damage.*

Preventive vs Reactive Functions in NIST Cybersecurity Framework 2.0

REACTIVE FUNCTIONS

- *(During & after an attack – damage control & recovery)*

5.RESPOND

Nature: Reactive

Why reactive:

- Activated **after an incident is detected**
- Focuses on containment, eradication, communication

Examples:

- Incident response execution
- Regulatory notification
- Ransomware containment

Preventive vs Reactive Functions in NIST Cybersecurity Framework 2.0

6. RECOVER

- **Nature:** Reactive + Corrective

Why reactive:

- Restores systems and services
- Improves resilience for the future

Examples:

- System restoration
- DR/BCP activation
- Lessons learned & improvement

Why Security Frameworks Are Important

- They provide consistency in security practices
- Support compliance with legal and regulatory requirements
- Help organisations identify and manage risks systematically

Key Components of a Security Framework

- Security policies define rules and expectations
- Standards and guidelines support policy implementation
- Controls enforce protection mechanisms

Security Governance

- Governance defines responsibility and accountability for security
- Senior management oversight is essential
- Clear roles improve decision-making and risk ownership

Risk Management Fundamentals

- Risk is the likelihood of a threat exploiting a vulnerability
- Risk management identifies, analyses, and mitigates risks
- Frameworks embed risk management into security planning

Risk Assessment Process

- Identify assets and threats
- Assess vulnerabilities and potential impact
- Prioritise risks based on likelihood and severity

Security Policies

- Policies define acceptable and unacceptable behaviour
- They guide employees and system users
- Policies must be clear, enforceable, and reviewed regularly

Security Controls

- Technical controls include firewalls and encryption
- Administrative controls include policies and training
- Physical controls protect facilities and hardware

NIST Cybersecurity Framework

- Widely used international security framework
- Five core functions: Identify, Protect, Detect, Respond, Recover
- Supports risk-based security management

ISO/IEC 27001 Framework

- International standard for information security management
- Focuses on Information Security Management Systems (ISMS)
- Emphasises continual improvement

Other Security Frameworks

- COBIT focuses on IT governance
- PCI DSS addresses payment card security
- Framework selection depends on organisational needs

Applying Frameworks in Practice

- Frameworks must be tailored to the organisation
- Risk appetite and business context are critical
- Continuous monitoring and improvement are required

Challenges in Using Frameworks

- Complexity and cost of implementation
- Lack of organizational support
- Keeping frameworks updated with evolving threats